

Graph Writeup by 菜叶片

初始信息收集

端口扫描

```
A yepian 15:33 11GiB/26GiB
• sudo nmap -sS -A -p- --min-rate 3000 192.168.56.114
[sudo] yepian 的密码:
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-02 15:33 +0800
Nmap scan report for 192.168.56.114
Host is up (0.000070s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.5
| ftp-syst:
|   STAT:
| FTP server status:
|   Connected to 192.168.56.1
|   Logged in as ftp
|   TYPE: ASCII
|   No session bandwidth limit
|   Session timeout in seconds is 300
|   Control connection is plain text
|   Data connections will be plain text
|   At session startup, client count was 3
|   vsFTPD 3.0.5 - secure, fast, stable
|_End of status
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_-rwxrwxrwx  1 0      0      8 May 31 14:03 passwd [NSE: writeable]
22/tcp    open  ssh      OpenSSH 10.3 (protocol 2.0)
5900/tcp  open  vnc      VNC (protocol 3.8)
| vnc-info:
|   Protocol version: 3.8
|   Security types:
|     VeNCrypt (19)
|     VNC Authentication (2)
|   VeNCrypt auth subtypes:
|     VNC auth, Anonymous TLS (258)
|_   Unknown security type (2)
MAC Address: 08:00:27:18:C5:51 (Oracle VirtualBox virtual NIC)
```

NSE提示FTP可匿名登录 其中文件passwd权限777

检查FTP

匿名登录FTP 下载文件passwd 发现是八字节不可读数据

登录VNC

结合VNC服务开启 判断这是VNC的passwd文件

用 jeroennijhof/vncpwd 解密出明文密码hello1

其实是问AI了 我刚用Linux的时候 喜欢用kali自带的tightvncserver 却从来没研究过VNC的密码认证过程 也没发现有这么个文件存储VNC密码

```

A yepian  ..../vncpwd  ? master ?  v16.1.1  16:44  12GiB/26GiB
  ● ▶ ./vncpwd
Usage: vncpwd <password file>

A yepian  ..../vncpwd  ? master ?  v16.1.1  16:44  12GiB/26GiB
  ✕ ▶ ./vncpwd ../passwd
Password: hello1

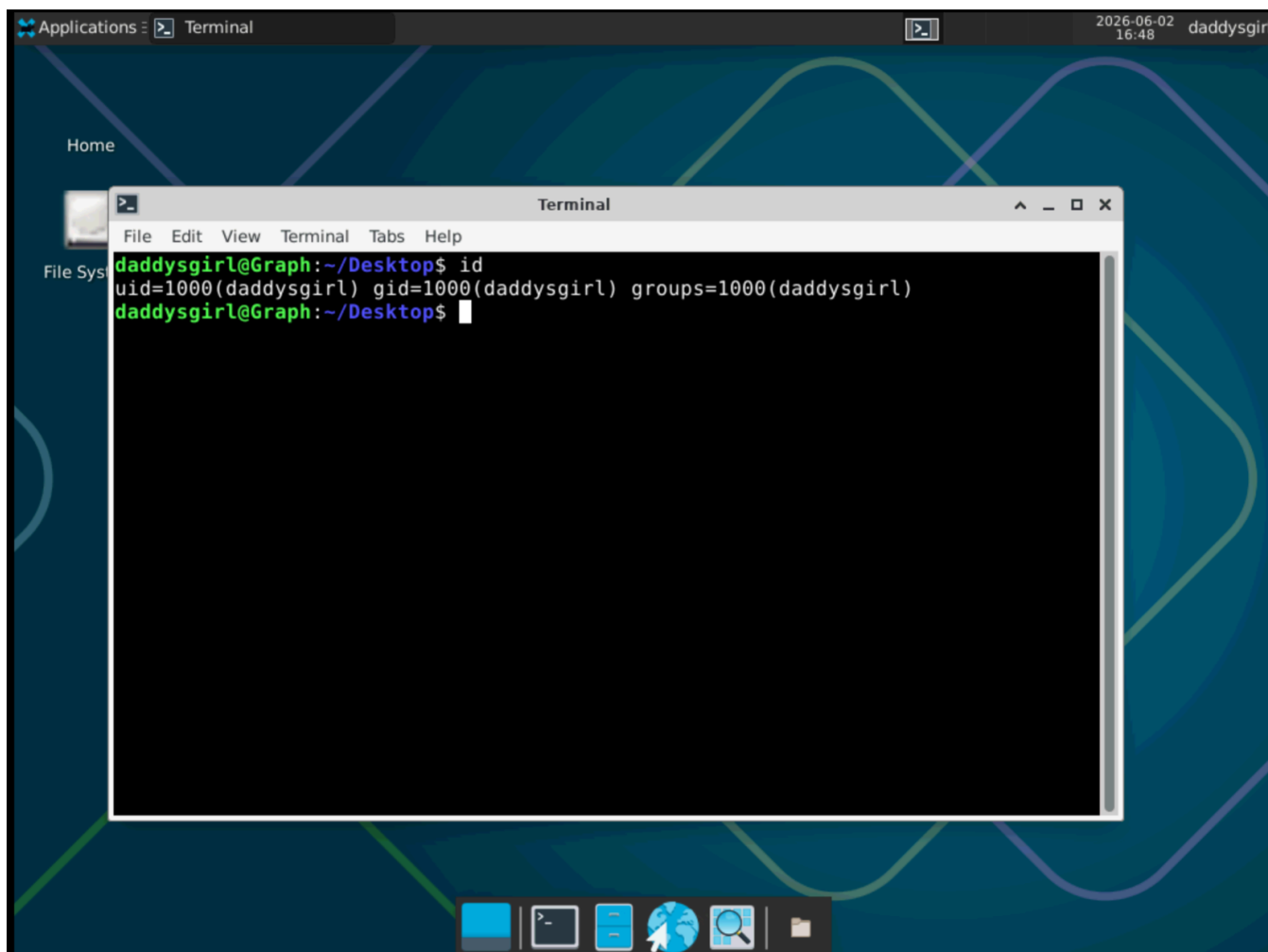
A yepian  ..../vncpwd  ? master ?  v16.1.1  16:44  12GiB/26GiB
  ● ▶ |
```

爆破用户名 发现有爆破防护 尝试用空用户名登录 成功

```

639 | void make3key(aptr, kptr)
msf|auxiliary(scanner/vnc/vnc_login) > set PASSWORD hello1
PASSWORD => hello1
A msf|auxiliary(scanner/vnc/vnc_login) > vset RHOSTS 192.168.56.114
RHOSTS => 192.168.56.114
msf|auxiliary(scanner/vnc/vnc_login) > run
[*] 192.168.56.114:5900 - 192.168.56.114:5900 - Starting VNC login sweep
A [!] 192.168.56.114:5900 master No active DB6-1.Credential4data2will2notBbe saved!
  ● [+] 192.168.56.114:5900 - 192.168.56.114:5900 - Login Successful: :hello1
```

用Remmina连接 (我很喜欢的远程桌面客户端)



本地权限提升

关于PolKit

收集很久信息 没找到什么 问了下sublarge 得到hint `polkit`

我了解的polkit提权 比较重要的配置文件

- actions/policies `/usr/share/polkit-1/actions`
- rules `/usr/share/polkit-1/rules.d`
- extra custom rules `/etc/polkit-1/`

发现 `/etc/polkit-1/rules.d` 不可读

实际上我对PolKit并不怎么了解 HTB的课程也仅仅把 `actions` 和 `rules` 归类为两种配置文件

对于Polkit作用也只是与sudo类比 攻击向量侧重在配置错误和CVE-2021-4034 aka pwnkit

实际上他的架构并不与sudo相同

- actions XML 定义了可授权的的操作
- rules JS 作为后置覆盖机制

以题目中的thunar做例子

`org.xfce.thunar.policy` 文件注册了action

- `<action>` 的属性节点id 定义了action的标识符
- `<annotate>` 的属性节点key 定义了可执行文件路径
- 定义了某些常量 比如 `allow_gui: true`
- 定义了默认策略 `allow_any: no` , `allow_inactive: auth_admin` ...

```
<?xml version="1.0" encoding="UTF-8"?>
<!DOCTYPE policyconfig PUBLIC
"-//freedesktop//DTD PolicyKit Policy Configuration 1.0//EN"
"http://www.freedesktop.org/standards/PolicyKit/1/policyconfig.dtd">
<policyconfig>
  <vendor>Thunar</vendor>
  <vendor_url>https://xfce.org/</vendor_url>
  <icon_name>org.xfce.thunar</icon_name>
  <action id="org.xfce.thunar">
    <description>Run Thunar as root</description>
    <message>Authentication is required to run Thunar as root.</message>
    <defaults>
      <allow_any>no</allow_any>
      <allow_inactive>auth_admin</allow_inactive>
      <allow_active>auth_admin</allow_active>
    </defaults>
    <annotate key="org.freedesktop.policykit.exec.path">/usr/bin/thunar</annotate>
    <annotate key="org.freedesktop.policykit.exec.allow_gui">true</annotate>
  </action>
```

用户执行 `pkexec thunar` polkitd根据注册的exec.path 匹配到 `org.xfce.thunar.policy`

接着 polkitd评估rules 按照文件名开头的数字 从小到大排序优先级

- 50-default.rules 若用户为wheel组 无需密码allow —— 无效果
- 99-thunar.rules 若 `action.id` 为 `org.xfce.thunar` 返回result yes —— 返回yes

于是按照99-thunar.rules的结果 最终返回yes

利用PolKit提升权限

回到这道题

执行 `pkaction` 我们可以得知 注册了以下actions

```
org.freedesktop.UPower.enable-charging-limit
org.freedesktop.policykit.exec
org.xfce.power.backlight-helper
org.xfce.power.xfce4-pm-helper
org.xfce.session.xfsm-shutdown-helper
org.xfce.thunar
```

什么调整电源电量最大值 休眠重启关机 这些对本地提权好像都没什么用

倒是这个 `org.xfce.thunar` 很可疑

由于我们访问不了 `/etc/polkit-1/rules.d` 不确定有没有rules可以让我们通过认证

但是还是可以试一下执行 `pkexec thunar`

成功以root身份运行thunar

我们只知道actions列表 并不知道有没有权限执行

也不算猜...就是...要勇于尝试? 默认值是不能 但是万一呢?